

# מעבדה 07 — סריקת רשת עם Nmap

גרסת ענן (Azure for Students) | Module 6 | משך: 2 שעות

## מידע על המעבדה

|       |                                                                                                     |
|-------|-----------------------------------------------------------------------------------------------------|
| מודול | Module 6 — יסודות אבטחת סייבר                                                                       |
| נושא  | Active Reconnaissance — סריקת רשת עם Nmap                                                           |
| משך   | 2 שעות                                                                                              |
| מטרה  | ללמוד לסרוק רשת, לגלות מכונות פעילות, לזהות פורטים פתוחים, שירותים וגרסאות, ולהריץ סקריפטי פגיעויות |

**REF** חומר עזר: פתחו את **Nmap Cheat Sheet** מתיקיית ה-Toolbox — כל הפקודות, התחבירים והפורטים הנפוצים שם.

**LEGAL** סריקת רשתות ומערכות מותרת **אך ורק** על מערכות שבבעלותכם או שיש לכם הרשאה כתובה מפורשת לסרוק. סריקה ללא אישור היא **עבירה פלילית**. בניסוי הזה אנחנו סורקים רק מכונות שלנו או את [scanme.nmap.org](https://scanme.nmap.org) (יעד מורשה רשמית של Nmap).

## הכנת סביבת העבודה — Azure for Students

## שלב 1

התחברו ל-**Azure Portal**: <https://portal.azure.com>

(ראו **Azure for Students Guide** ב-Toolbox אם עדיין אין לכם חשבון)

## שלב 2

הרימו מכונת **Kali Linux**:

```
Virtual machines → + Create → Azure virtual machine
Resource group: cyberlabs-rg
Name: Kali-Lab07
Region: West Europe
Image: See all images → חפשו "Kali Linux"
Size: B1s (!חינם 750 שעות) או B2s
Authentication: Password
Username: kali
Password: סיסמה חזקה – רשמו
Inbound ports: SSH (22)
Review + create → Create
```

## שלב 3

חכו 2-3 דקות. לחצו **Go to resource**.  
העתיקו את ה-**Public IP**.

## שלב 4

התחברו ב-SSH:

```
# PowerShell או Terminal:
ssh kali@PUBLIC_IP_ADDRESS
```

הקלידו את הסיסמה שבחרתם.

בדקו Nmap:

```
nmap --version
```

... **OUTPUT** Nmap version 7.94

אם לא מותקן:

```
sudo apt update && sudo apt install nmap -y
```

**TIP** בשני המסלולים, היעד הראשי הוא [scanme.nmap.org](https://scanme.nmap.org) — אתר רשמי שמותר לסרוק.

## גילוי מכונות פעילות — Host Discovery

לפני שסורקים פורטים, צריך לדעת אילו מכונות בכלל פעילות ברשת.

### שלב 1

**Ping Scan** — בדקו אם היעד חי (ללא סריקת פורטים):

```
nmap -sn scanme.nmap.org
```

**OUTPUT** Host is up (0.15s latency). Nmap done: 1 IP address (1 host up) scanned in 0.52 seconds

**מה קרה:** Nmap שלח TCP SYN + ICMP Echo (ping) לפורט 443 + TCP ACK לפורט 80. אם אחד מהם חזר — המכונה פעילה.

### שלב 2

**Ping Sweep** — גלו כל המכונות הפעילות ברשת מקומית (רק אם יש לכם רשת מקומית):

```
# Host-Only network! רק למסלול מקומי עם
```

```
nmap -sn 192.168.56.0/24
```

**OUTPUT** Nmap scan report for 192.168.56.1 Host is up (0.00020s latency). Nmap scan report for 192.168.56.101 Host is up (0.0010s latency)

### שלב 3

**Discovery על ping** — אם חומת אש חוסמת ping:

```
nmap -Pn scanme.nmap.org
```

**מתי להשתמש:** כשאתם יודעים שהיעד קיים אבל הוא לא עונה ל-ping (חומת אש חוסמת ICMP).

? מה ההבדל בין `-sn` ל-`-Pn`? מתי תשתמשו בכל אחד?

## סריקת פורטים בסיסית — Port Scanning

עכשיו שאנחנו יודעים שהיעד חי, נבדוק אילו פורטים פתוחים.

### שלב 1

**סריקה בסיסית** — סורקת את 1,000 הפורטים הנפוצים:

```
nmap scanme.nmap.org
```

**OUTPUT** PORT STATE SERVICE 22/tcp open ssh 80/tcp open http 9929/tcp open nping-echo 31337/tcp open Elite

### הסבר:

- **open** = שירות פעיל ומאזין. אפשר להתחבר.
- **closed** = פורט נגיש, אין שירות. עונה עם RST.
- **filtered** = חומת אש חוסמת. לא ניתן לקבוע.

### שלב 2

**סריקה מהירה** — רק 100 הפורטים הכי נפוצים:

```
nmap -F scanme.nmap.org
```

**מתי להשתמש:** כשרוצים תוצאה מהירה וסקירה כללית.

### שלב 3

**סריקת פורטים ספציפיים:**

```
# פורט בודד
nmap -p 22 scanme.nmap.org

# מספר פורטים
nmap -p 22,80,443 scanme.nmap.org

# טווח
nmap -p 1-1000 scanme.nmap.org
```

סריקת כל 65,535 הפורטים (לוקח זמן!):

```
nmap -p- scanme.nmap.org
```

**TIP** זה יכול לקחת כמה דקות. הוסיפו `-T4` לזירוז: `nmap -p- -T4 scanme.nmap.org`

? הריצו `nmap -p 21,22,23,80,443,3389 scanme.nmap.org` — אילו פורטים פתוחים? אילו סגורים?  
אילו מסוננים? מה זה אומר לגבי השירותים על המכונה?

## סוגי סריקה — SYN vs TCP Connect

Nmap יכול לסרוק בכמה דרכים שונות. הנה שתיים המרכזיות:

### שלב 1

**SYN Scan (ברירת מחדל)** — חצי-פתוח, חמקני:

```
sudo nmap -sS scanme.nmap.org
```

**איך זה עובד:**

1. Nmap שולח SYN
2. אם היעד עונה SYN-ACK → הפורט **פתוח**
3. Nmap שולח RST (לא משלים את ה-Handshake)
4. אם היעד עונה RST → הפורט **סגור**
5. אם אין תשובה → הפורט **מסונן**

**למה חמקני?** לא משלים TCP Handshake = לא נרשם בלוגים של רוב האפליקציות.  
**דורש root!** בגלל שיוצר raw packets.

### שלב 2

**TCP Connect Scan** — חיבור מלא:

```
nmap -sT scanme.nmap.org
```

**ההבדל:** משלים את ה-TCP Handshake (SYN → SYN-ACK → ACK).  
**יתרון:** לא דורש root.  
**חסרון:** איטי יותר, נרשם בלוגים, פחות חמקני.

### שלב 3

**השוואה מעשית** — הריצו את שניהם ושימו לב לזמנים:

```
# 1 סריקה: SYN (דורש sudo)
sudo nmap -sS -p 22,80,443 scanme.nmap.org
```

```
# 2 סריקה: TCP Connect (ללא sudo)
nmap -sT -p 22,80,443 scanme.nmap.org
```

**השוא:** האם התוצאות זהות? מי מהיר יותר?

? למה SYN Scan נקרא "חצי-פתוח" (Half-Open)? מה היתרון האבטחתי שלו מבחינת תוקף?



## זיהוי שירותים וגרסאות — Service Detection

לדעת שפורט 80 פתוח זה לא מספיק. צריך לדעת **מה** רץ ו**באיזו גרסה**.

### שלב 1

זיהוי גרסאות שירות:

```
nmap -sV scanme.nmap.org
```

**OUTPUT** PORT STATE SERVICE VERSION 22/tcp open ssh OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 80/tcp open http Apache httpd 2.4.7 ((Ubuntu)) 9929/tcp open nping-echo Nping echo

**שימו לב:** עכשיו אנחנו רואים **OpenSSH 6.6.1p1** ו-**Apache 2.4.7** — גרסאות ספציפיות! אפשר לחפש CVE עבורן.

### שלב 2

זיהוי מערכת הפעלה:

```
sudo nmap -O scanme.nmap.org
```

**OUTPUT** OS details: Linux 4.15 - 5.8

**דורש root!** משתמש ב-TCP/IP fingerprinting.

### שלב 3

"הסריקה הקלאסית" — שירותים + גרסאות + OS + סקריפטים:

```
sudo nmap -A -T4 scanme.nmap.org
```

**הדגל -A** שווה ערך ל: `-sV -O -sC --traceroute`

זו הפקודה הכי שימושית לסיור מלא על יעד.

## שמירת תוצאות לקובץ (חשוב לתיעוד!):

```
# כל הפורמטים בבת אחת  
sudo nmap -A -T4 -oA scan_scanme scanme.nmap.org
```

**OUTPUT** נוצרים 3 קבצים: scan\_scanme.nmap — פלט קריא XML — scan\_scanme.xml לייבוא לכלים  
scan\_scanme.gnmap — פורמט grepable

```
# צפו בתוצאות  
cat scan_scanme.nmap
```

**TIP תמיד** שמרו תוצאות עם `-oA`. תודו לעצמכם כשתצטרכו לכתוב דוח.

? לפי תוצאות הסריקה, מצאו את גרסת Apache ו-OpenSSH. חפשו ב-Google: `"Apache 2.4.7 CVE"` — האם יש פגיעויות ידועות?

Nmap Scripting Engine (NSE) מאפשר להריץ סקריפטים מתקדמים — מזהוי פגיעויות ועד brute force.

## שלב 1

סקריפטים בסיסיים (default) — בטוחים ושימושיים:

```
nmap -sC scanme.nmap.org
```

שווה ערך ל- `--script default`. מריץ סקריפטים כמו: HTTP, SSH host key, banner grabbing, title.

## שלב 2

הצגת כותרת עמוד ווב:

```
nmap --script http-title -p 80 scanme.nmap.org
```

```
!OUTPUT PORT STATE SERVICE 80/tcp open http |_http-title: Go ahead and ScanMe
```

## שלב 3

סריקת פגיעויות:

```
nmap --script vuln -p 22,80 scanme.nmap.org
```

מה זה עושה: מריץ את כל הסקריפטים בקטגוריית `vuln` — בדיקת פגיעויות ידועות. ⚠️ זה יכול לקחת כמה דקות.

## שלב 4

בדיקת SMB (EternalBlue):

```
# רק על מכונה שלכם! לא על #
nmap --script smb-vuln* -p 445 TARGET_IP
```

רלוונטי אם: יש לכם Windows Server ב-Lab. סקריפט זה בודק את חולשת CVE-2017-0144 שגרמה ל-WannaCry.

```
nmap --script ssl-cert -p 443 scanme.nmap.org
```

**OUTPUT** 443/tcp open https | ssl-cert: Subject: commonName=scanme.nmap.org | Issuer: commonName=R11, organizationName=Let's Encrypt | Not valid before: 2024-... | Not valid after: ...-2024

מה זה מצא? מה משמעות התוצאות — `nmap --script http-enum -p 80 scanme.nmap.org` ? הריצו

מבחינת אבטחה?

## תרחיש מעשי — סיור מלא על יעד

עכשיו משלבים הכל. דמיינו שקיבלתם אישור לסרוק את `scanme.nmap.org` כחלק מבדיקת חדירה.

### שלב 1

**שלב 1 — גילוי:** האם היעד חי?

```
nmap -sn scanme.nmap.org
```

**רשמו:** כן/לא, IP שהתגלה, latency.

### שלב 2

**שלב 2 — סריקה מהירה:** מה פתוח?

```
nmap -F -T4 scanme.nmap.org
```

**רשמו:** רשימת פורטים פתוחים.

### שלב 3

**שלב 3 — סריקה מעמיקה:** גרסאות + OS + סקריפטים

```
sudo nmap -A -T4 -p 22,80,9929,31337 -oA full_scan scanme.nmap.org
```

**רשמו:** שירותים + גרסאות + מערכת הפעלה.

### שלב 4

**שלב 4 — פגיעויות:**

```
nmap --script vuln -p 22,80 -oN vuln_scan.txt scanme.nmap.org
```

**רשמו:** האם נמצאו פגיעויות? אילו CVEs?

שלב 5 — תיעוד: צרו טבלת ממצאים:

| הערות | מצב   | גרסה            | שירות    | פורט      |  |
|-------|-------|-----------------|----------|-----------|--|
| 22    | SSH   | OpenSSH 6.6.1p1 | open     | גרסה ישנה |  |
| 80    | HTTP  | Apache 2.4.7    | open     | גרסה ישנה |  |
| 443   | HTTPS | ?               | filtered | חומת אש?  |  |
| 3389  | RDP   | ?               | filtered | לא פתוח   |  |

מלאו את הטבלה עם התוצאות שלכם.



## צ'קליסט סיום — Lab 02

### סביבה

☐ Nmap מותקן ועובד (מקומי או ענן)

☐ יש חיבור אינטרנט ל- `scanme.nmap.org`

### Host Discovery

☐ הרצתי `nmap -sn` וראיתי "Host is up"

☐ אני מבין את ההבדל בין `-sn` ל- `-Pn`

### Port Scanning

☐ הרצתי סריקה בסיסית וזיהיתי פורטים פתוחים

☐ הרצתי סריקת פורטים ספציפיים (`-p`)

☐ אני מבין מה זה open / closed / filtered

### Scan Types

☐ הרצתי SYN Scan (`-sS`) ו-TCP Connect-I (`-sT`)

☐ אני מבין למה SYN Scan חמקני יותר

### Service Detection

☐ הרצתי `-sV` וזיהיתי גרסאות שירותים

☐ הרצתי `-A` (סריקה אגרסיבית מלאה)

☐ שמרתי תוצאות עם `-oA`

### NSE Scripts

☐ הרצתי `--script http-title`

☐ הרצתי `--script vuln`

☐ הרצתי `--script ssl-cert`

### תרחיש מלא

☐ ביצעתי סיור 5 שלבים על [scanme.nmap.org](https://scanme.nmap.org)

☐ מילאתי טבלת ממצאים

☐ צילמתי מסך של התוצאות





## ניקוי אחרי המעבדה

### מסלול מקומי

- כבו את Kali VM
- שמרו את קבצי הסריקה (scan\_scanme.\*) לתיקייה ייעודית

### מסלול ענן — Azure

- **Stop (Deallocate)** את ה-VM (אם יש עוד מעבדות)
- **Delete** (אם סיימתם — סמנו גם OS disk + NIC)
- ראו **Azure for Students Guide** ב-Toolbox